Berner Fachhochschule
Haute école spécialisée bernoise
Bern University of Applied Sciences



IAM

Authentifizierungsmittel & -faktoren

Prof. Dr. Annett Laube, HS 26, HSLU

Übersicht

- Authentifizierungsmittel & Credential
- Kategorien von Authentifizierungsmittel
- Beispiele Authentifizierungsmittel

Authentifizierung - Wiederholung

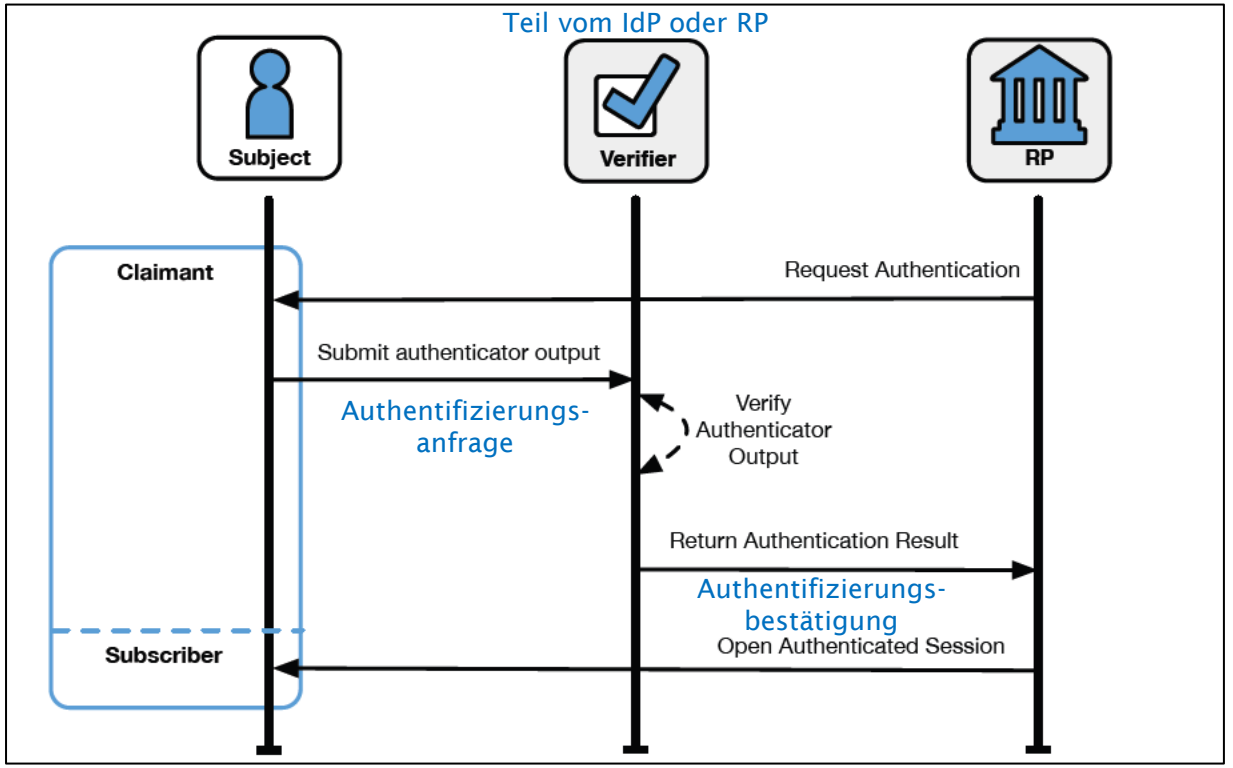


- **Authentifizierung** ist der wiederkehrende Prozess der Überprüfung der Zugehörigkeit einer (Teil-)Identität zu einem Subjekt.
  - Prozess zur Überprüfung der behaupteten (digitalen) Identität
- Dabei wird **verifiziert**, ob die erfassten persönlichen **Identitätsnachweise** (Credentials) mit einer gewissen Sicherheit zur präsentierten (Teil)Identität gehören.
- Die Stärke einer Authentifizierung ist abhängig von der Stärke der Bindung der (Teil-)Identität zum Subjekt und damit von der Anzahl und dem Typ der **Authentifizierungsmittel**.

- Synonyme: Authentifikation, Authentisierung, (Login)

Authentifizierung

"**Authentication** is the **process** of determining the validity of one or more authenticators (*Authentifizierungsmitte*l) used to claim a digital identity by establishing that a subject attempting to access a digital service (*relying party, RP*) is in control of the secrets used to authenticate."[NIST 800-63-4B]



NIST Authentication Process

Übersicht

- Authentifizierungsmittel & Credential
- Kategorien von Authentifizierungsmittel
- Beispiele Authentifizierungsmittel

Authentifizierungsmittel

- **Authentifizierungsmittel** sind Informationen und/oder Prozesse, die zur Authentifizierung eines Subjektes verwendet werden können.

- Ein Authentifizierungsmittel kann
  - einen SFA (*single-factor authenticator*)

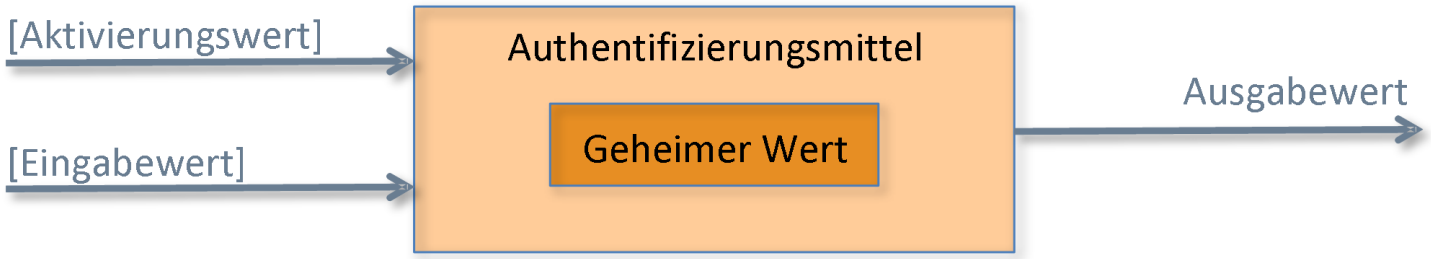
  oder
  - auch mehrere unabhängige Authentifizierungsfaktoren MFA (*multi-factor authenticator*)

  benutzen.

- **Synonyme**: Authenticator, Authentication token

Authentifizierungsmittel - Schema

- Der vom Authentifizierungsmittel generierte Ausgabewert wird durch eine mathematische Funktion aus einem geheimen Wert (z.B. privater Schlüssel), einem oder mehreren optionalen Aktivierungswerten (z.B. PIN oder biometrisches Merkmal), und einem oder mehreren optionalen Eingabewerten (z.B. Zufallswerten oder Challenges) generiert.
- Im Trivialfall kann das Authentifizierungsmittel der geheime Wert selbst sein (z.B. im Fall eines Passwortes).




```
Ausgabewert =
        Authentifizierungsfunktion (geheimer Wert,
                                    [Aktivierungswerte],
                                    [Eingabewerte])
```

Credential = Identitätsnachweis

- Ein **Identitätsnachweis** (**Credential**) stellt eine Menge von Daten (keine Hardware oder andere physische Container) dar, mit der eine (Digitale) Identität an ein Authentifizierungsmittel gebunden wird, welches vom Subjekt kontrolliert wird.
- Die Bindung erfolgt über den Identifikator der Identität.
- Das *Credential* wird vom Verifier zusammen mit dem Ausgabewert des Authentifizierungsmittels zum Nachweis der behaupteten Identität verwendet.
  - Beispiele:
    - der Hash eines Passwortes,
    - ein Abbild eines biometrischen Merkmals,
    - ein Zertifikat.

- Durch den Nachweis des Besitzes eines Authentifizierungsmittels kann sich das Subjekt immer wieder authentisieren.

Übersicht

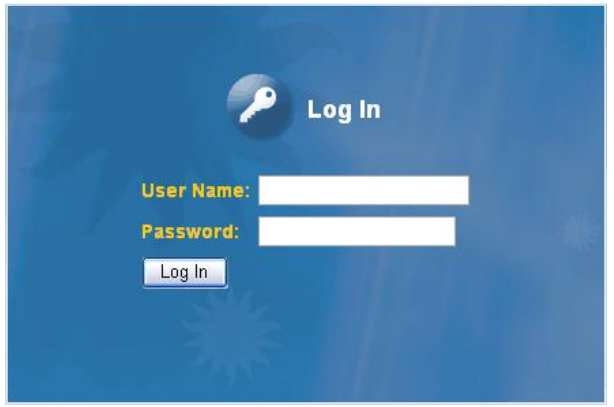
- Authentifizierungsmittel & Credential
- Kategorien von Authentifizierungsmittel
- Beispiele Authentifizierungsmittel

Kategorien von Authentifizierungsmittel (1/2)

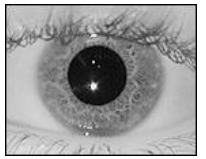
- **besitzbasierender Authentifizierungsfaktor (something you have):**
  - beruht auf Besitz (etwas, das das Subjekt besitzt)
  - Soft-Token/Hardware-Token mit privatem Schlüssel, elektronischer Pass oder ID-Karte, Authentisierungstoken, Zertifikate, kryptographische Schlüssel



- **kenntnisbasierender Authentifizierungsfaktor (something you know):**
  - beruht auf Wissen (etwas, das **nur** das Subjekt weiss)
  - Geheime Informationen wie Passwörter oder PIN's



Kategorien von Authentifizierungsmittel (2/2)







- **inhärenter Authentifizierungsfaktor (something you are):**
  - beruht auf einem biometrischen Merkmal (etwas, das das Subjekt ist)
  - Iris, Netzhaut, Gesichtsmerkmale, Fingerabdrücke, Venenmuster in Hand oder Fingern, …
- **verhaltensbasierter Authentifizierungsfaktor (something you do):**
  - beruht auf Verhalten (etwas, was das Subjekt typischerweise macht)
  - z.B. dynamisches Unterschriftsmuster, Tippgeschwindigkeit, Gangart oder Stimmmuster.

Multiple SF-Authenticator ↔ MF-Authenticator

Mehrfaktoren-Authentisierung kann auf zwei Arten umgesetzt werden:

- ***Multiple single-factor-authenticator:***

  Mehrere SF-Authentifikatoren werden dem IdP präsentiert. Jeder benötigt ein eigenes auf dem IdP registriertes Credential.



- ***Multi-factor authenticator:***

  Hat nur ein registriertes Credential, welches dem IdP präsentiert wird. Das Geheimnis auf dem Authenticator ist durch einen zweiten Faktor geschützt (Aktivierungsdaten). Dieser zweite Faktor kann eine PIN oder ein biometrisches Merkmal sein.



Passwörter werden wiederverwendet…



…und können abgehört werden







Hardware Keylogger







Fake USB Keylogger in Memory Stick

Versteckte Spionagekamera am Schlüssel

Passwortlose Authentifizierung

- Authentifizierung, bei der auf den Einsatz von Passwörtern verzichtet wird.
- Gängige Methoden für passwortlose Authentifizierung sind:
  - Biometrische Merkmale (z.B. Fingerprints oder Gesichtserkennung),
  - Einmal-Passwörter (z.B. Google Authenticator),
  - Magic Links, einzigartige, einmal verwendbare Links per E-Mail oder SMS (z.B. Slack),
  - Hardware-Token (z.B. Yubikey oder Smartcards),
  - Push-Nachrichten.
- Eine passwortlose Authentifizierung ist nicht zu verwechseln mit einer Multi-Faktor-Authentifizierung (MFA), bei welcher als Faktor durchaus ein Passwort als Authentifizierungsmittel verwendet werden kann.

Übersicht

- Authentifizierungsmittel & Credential
- Kategorien von Authentifizierungsmittel
- Beispiele Authentifizierungsmittel

Beispiele für Authentifizierungsmittel

- Memorized Secrets (Gespeichertes Geheimnis)
- Look-Up Secrets (Nachschlagbares Geheimnis)
- Smartcards

Memorized Secrets (gespeichertes Geheimnis)

- Beispiele: Passwort oder PIN (auch Sicherheitsfragen)
- geheim gehaltene Werte, die meist vom Benutzer gewählt und in seinem Gedächtnis oder an einem anderen sicheren Aufbewahrungsort gespeichert werden.
- Passwörter müssen über eine genügend hohe Komplexität und Zufälligkeit verfügen, um von einem Angreifer nicht erraten oder auf sonstige Art und Weise berechnet werden können.
- *Passwort Policies* legen die Regeln zur Länge, Komplexität, Zeichenmix, Ablaufdauer und Wiederverwendung fest und bestimmen somit die Stärke des Memorized Secrets.

Typ	SF
Kategorie	kenntnisabhängig
Geheimer Wert	Passwort/PIN
Aktivierungswert	-
Authentifizierungsfkt.	Keine oder Hash-Fkt.
Ausgabewert	Passwort oder Hash des Passworts
Credential	(Passwort oder) Hash des Passworts

Beispiel Policy: NIST Password Guidelines

Look-Up Secrets (Nachschlagbares Geheimnis)

- Beispiele: Strichlisten (engl. *tally sheet*), TAN-Blöcke, Recovery Keys
- *Look-Up Secrets* enthalten eine Liste von (alpha-) numerischen Werten, die zuvor zwischen dem Subjekt und dem IdP ausgetauscht wurden. Zur Authentifizierung muss der Benutzer einen bestimmten Wert aus dieser Liste angegeben.
- Werden heute oft als als Notfall- oder Backup-Codes verwendet.
- Die ausgetauschten Werte müssen zufällig generiert werden. Sie dürfen meist nur einmal benutzt werden und eine genügend hohe Entropie besitzen. Die Anzahl der mögl. Versuche muss limitiert sein.

Typ	SF
Kategorie	besitzabhängig
Geheimer Wert	(alpha-)numerische Werte
Aktivierungswert	-
Authentifizierungsfkt.	Selektion
Ausgabewert	(alpha-)numerischer Wert
Credential	gewählter (alpha-) numerischen Wert

Smartcard



- Smartcards sind physische Karten mit eingebettetem Mikrochip, der kryptografische Schlüssel und Zertifikate sicher speichert.
- Sie können per Lesegerät eingesteckt oder drahtlos (per NFC) ausgelesen werden.
- MFA durch Kombination mit PIN
- Gilt als „Multi-Factor Cryptographic Device”
- Ein solches Gerät enthält auch eingebettete Software. Der IdP ist für diese zuständig und kontrolliert die Art und Weise, wie die Software funktioniert.

Typ	MF
Kategorie	Besitz + Kenntnisabhängig
Geheimer Wert	Private Key
Aktivierungswert	PIN
Authentifizierungsfkt.	Signatur
Ausgabewert	Signatur (Nonce)
Credential	Zertifikat/Public Key

Mögliche Bedrohungen & Lösungsstrategien

- Eine Liste möglicher Bedrohungen, wenn Authentifizierungsmittel in falsche Hände fallen:
  - NIST Special Publication 800-63B-4.2: https://pages.nist.gov/800-63-4/sp800-63b.html Kap. 6.1.
  - Lösungsansätze in Kap. 6.2

Unterschiede hinsichtlich des authentifizierenden Subjekts

	Person	Ding / Maschine / Service
Wichtigste Anforderung	Benutzerfreundlichkeit	Automatisierung
Authentifizierungsmittel	Passwörter, Biometrie, OTP, Smartcards	Zertifikate, API-Keys, Token
Authentifizierungsprotokolle	Interaktiv OAuth, OpenID Connect, SAML, Kerberos	Automatisiert, im Hintergrund TLS/SSL, Mutual TLS, oder Tokenbasierte Authentifizierung
Sicherheitsbedrohungen	**soziale Angriffe**, wie Phishing oder Passwortdiebstahl menschliches Fehlverhalten oder Fehlern.	**technische Angriffe**, wie das Ausnutzen von Schwachstellen in Software, Zertifikatsdiebstahl oder Man-in-the-Middle-Angriffe.

Wiederholungsfragen / Diskussion

1. Welche Funktion haben Authentifizierungsmittel und Credential bei der Authentifizierung?

2. Welche Arten von Authentifizierungsmittel gibt es?

3. Wodurch unterscheiden sich die Authentifizierungsmittel von Personen und Maschinen?